

RISK MANAGEMENT FRAMEWORK

Contents

Introduction 2

Personal Risk Management Framework 3

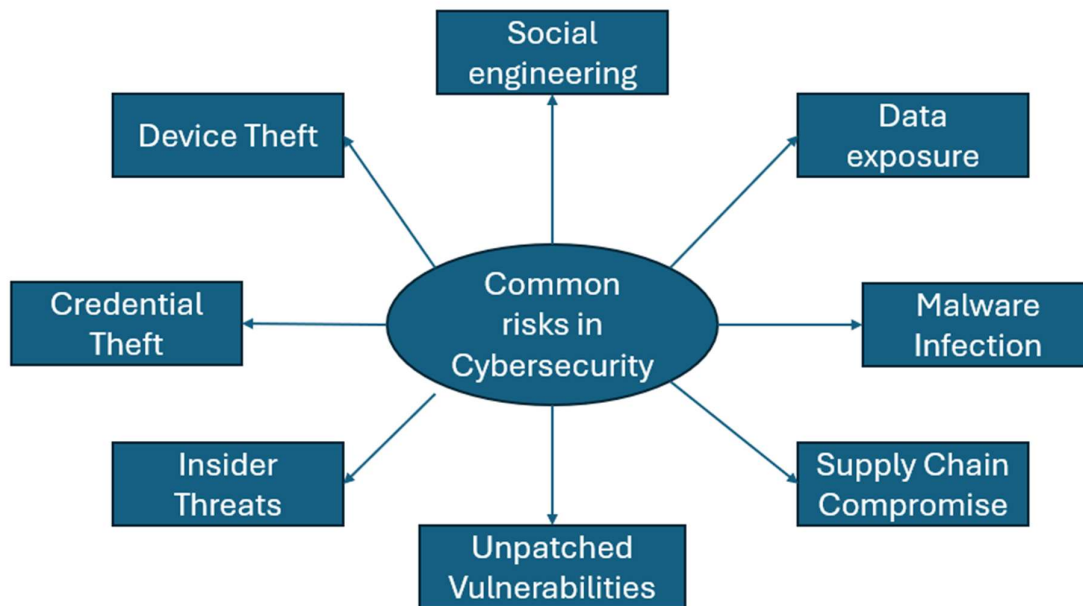
Organisational Risk Management Framework..... 4

Risk Management Framework Trade-offs..... 5

Introduction

This risk management framework is designed to aid both users and companies in identifying and handling risks. This framework was developed as it is important to handle risks within security. This can also be applied for other contexts outside of security. The 5 most common risks for personal security in 2026 are Credential theft / account takeover, Malware infection, Device theft / loss, social engineering and Data exposure via third-party services. While the 5 most common risks for organisations are Ransomware, Supply chain compromise, Insider threat, Credential theft and unpatched vulnerabilities. If you don't understand these risks, you may find information about them in my other frameworks, or you can do your own research.

This risk management framework cannot provide perfect discoverability or handling of risks in both personal and organisational environments. However, this framework can allow for a reduction of risks in security set-ups. Do not blindly trust this framework as you're only tool for discovering and handling vulnerabilities or risks within your own system. Adapt this framework as needed based on your threat model and resources.



The spider diagram above shows the common risks in Cybersecurity for both personal and organisational environments. It is important to remember that the diagram above does not cover all risks within all environments. Research on risks should be done based on your threat model and resources as a person or company.

Personal Risk Management Framework

- This section is designed to aid users in handling risks effectively within their IT systems.
- I would not recommend using this section if you want a framework for organisation risk management.
- This section should be adapted based on your threat model.
- The first step is to calm down
- This can be done by taking a few deep breaths or releasing anger in a non-harmful way
- The second step is discovery
- This is where you will be discovering potential risks within your systems
- This could be done through daily security check ins, small-scale testing and automated scanning
- This step is important to discover risks within your systems
- The third step is assessment
- This is where you will look at the risk's impact, priority and linkage to your threat model.
- This can be done through the structure What (What the risk is) → Impact (How does this risk affect you or your systems?) → Priority (How important is this risk in terms of impact? High, medium, low) → Threat model (What threat model can this risk be exploited by?)
- The fourth step is response
- This is where you will respond effectively and efficiently to the risk
- Risks can be responded by acceptance, mitigation, sharing.
- Acceptance is where you accept that you can't prevent the risk with current resources and document the risk and why it can't be mitigated.
- Mitigation is where you implement countermeasures like strong passwords, MFA and OPSEC.
- Sharing is where you transfer the risk to a different provider for example to a cloud provider
- The final step is to document the risk
- This means that you will document the process of each step such as the discovery, assessment and response to the risk
- This step can be done through the structure what (What the risk is) → Impact (How the risk affects systems or you) → Threat model (What threat model can exploit this risk) → Response (How did you respond to the risk) → Potential improvements (What could be improved for next time)
- Make sure to repeat this risk management process again based on your threat model
- For example, most people may repeat this process monthly while high risk users might do it weekly.

Organisational Risk Management Framework

- This section is made to aid organisations with managing risks effectively within their IT systems.
- I do not recommend using this section for personal security as it uses more technical terms and organisation-specific language.
- The first step is discovery
- This means that organisations must find potential risks within their IT systems
- This can be done by automated scanning, pen testing and perhaps audits
- This step is important because it enables organisations to actively discover potential risks within their systems.
- The second step is assessment
- This means that organisations must assess the potential risk to understand its impact and respond effectively
- This can be done through the structure What (What the risk is) → Impact (Disruption to business operations, reputation damage or lawsuits if exploited) → Priority (How important is this risk? High, medium, low in terms of impact) → Threat model (What threat model could exploit this?) → Potential responses (How could this risk be responded to?).
- This step is important because it allows organisations to avoid false positives and understand risks on a fundamental level to respond to it.
- The third step is response
- This means that organisations must effectively and securely respond to the risk after assessment
- Organisations can respond to risks through acceptance, mitigation, transferring or avoidance.
- Acceptance is where an organisation accepts the risk and documents it securely online for others to know about. This can be done through ISACs or other methods
- Mitigation is where an organisation implements countermeasures such as IPS/IDS systems, password policy and RBAC.
- Transferring is where an organisation shares the risk with third-party provider like cloud providers or Cybersecurity firms like Cloudflare.
- Avoidance is where an organisation changes their approach to avoid a risk. This response should only be used in risks like natural disasters.
- The fourth step is documentation
- This means that organisations document the process of discovering and responding to the risk securely.
- This can be done through the structure what (What the risk is) → Impact (How the risk affects systems or you) → Threat model (What threat model can exploit this risk) → Response (How did you respond to the risk) → Potential improvements (What could be improved for next time)
- The final step is continuous monitoring of the risk where organisations continue to monitor the risk.

Risk Management Framework Trade-offs

- This risk management framework has trade-offs just like any other systems I have created so far.
- I have identified 4 main trade-offs with this framework.
- The first trade-off is time-consumption.
- This trade-off exists because it can take a long time to do this process for systems especially if the system has plenty of components and functions.
- This means that users and companies may not have the time to be discovering and managing risks using my framework.
- This trade-off can be managed by automation, targeted risk discovery and a risk management team if possible.
- The second trade-off is cognitive load.
- This trade-off exists because it can be mentally stressful to be constantly assessing your risks and managing them so effectively.
- This means that some users may not follow the framework effectively as its too stressful or mentally draining to do.
- This trade-off can be managed by automation, a risk review schedule, built-in breaks and accepting that you won't do it perfectly.
- The third trade-off is cost.
- This trade-off exists because some migrations and automation tools can be expensive to pay for.
- This means that some users may not be able to manage the risk effectively due to budget or resource limitations.
- This trade-off can be managed by using built-in security tools, free third-party security tools, budget management and using different risk responses.
- The fourth trade-off is complexity.
- This trade-off exists because documenting risks, setting up migrations and knowing when to respond to a risk in a certain way can be confusing.
- This means that users can make a lot of mistakes or may not be able to document the risks effectively in a way they can refer to later.
- This trade-off can be managed by practicing writing risk documentation, having a criteria system for each risk response and automating the process where possible.